

BÁO CÁO THỰC HÀNH

Môn học: Bảo mật Web và Ứng dụng

Lab 6: Bài kiểm tra kết thúc thực hành

GVHD: Ngô Khánh Khoa

Nhóm: 11

1. THÔNG TIN CHUNG:

Lớp: NT213.P11.ANTT.2

STT	Họ và tên	MSSV	Email
1	Nguyễn Đăng Quỳnh Như	22521050	22521050@gm.uit.edu.vn
2	Phạm Minh Tân	22521310	22521310@gm.uit.edu.vn
3	Lê Minh Quân	22521181	22521181@gm.uit.edu.vn
4	Đặng Đức Tài	22521270	22521270@gm.uit.edu.vn

2. NỘI DUNG THỰC HIỆN:

STT	Nội dung	Tình trạng	Trang
1	Yêu cầu 1	100%	
2	Yêu cầu 2	100%	
3	Yêu cầu 3	100%	
4	Yêu cầu 4	100%	
5	Yêu cầu 5	100%	
Điểm tự đánh giá			10/10

Phần bên dưới của báo cáo này là tài liệu báo cáo chi tiết của nhóm thực hiện

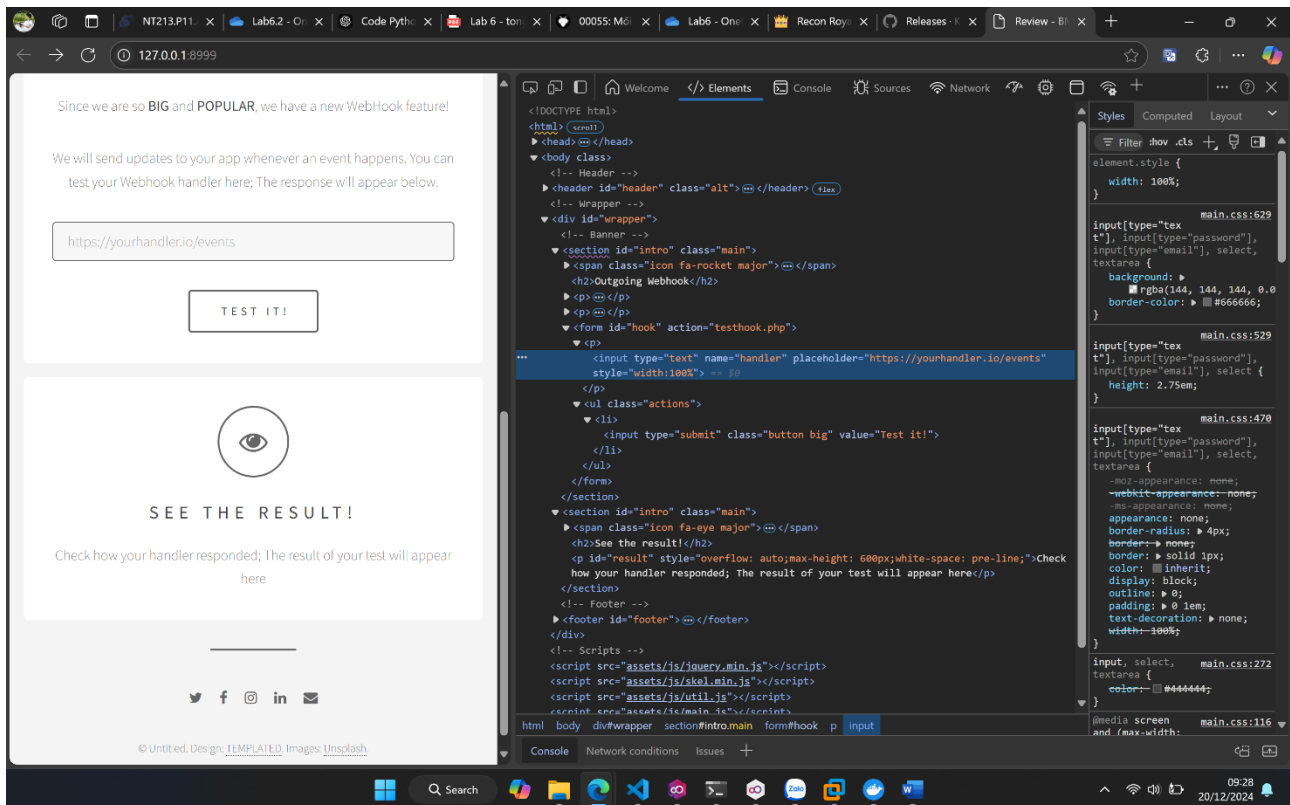
BÁO CÁO CHI TIẾT

Yêu cầu 1: Đề báo cáo lỗi hỏng tìm thấy được

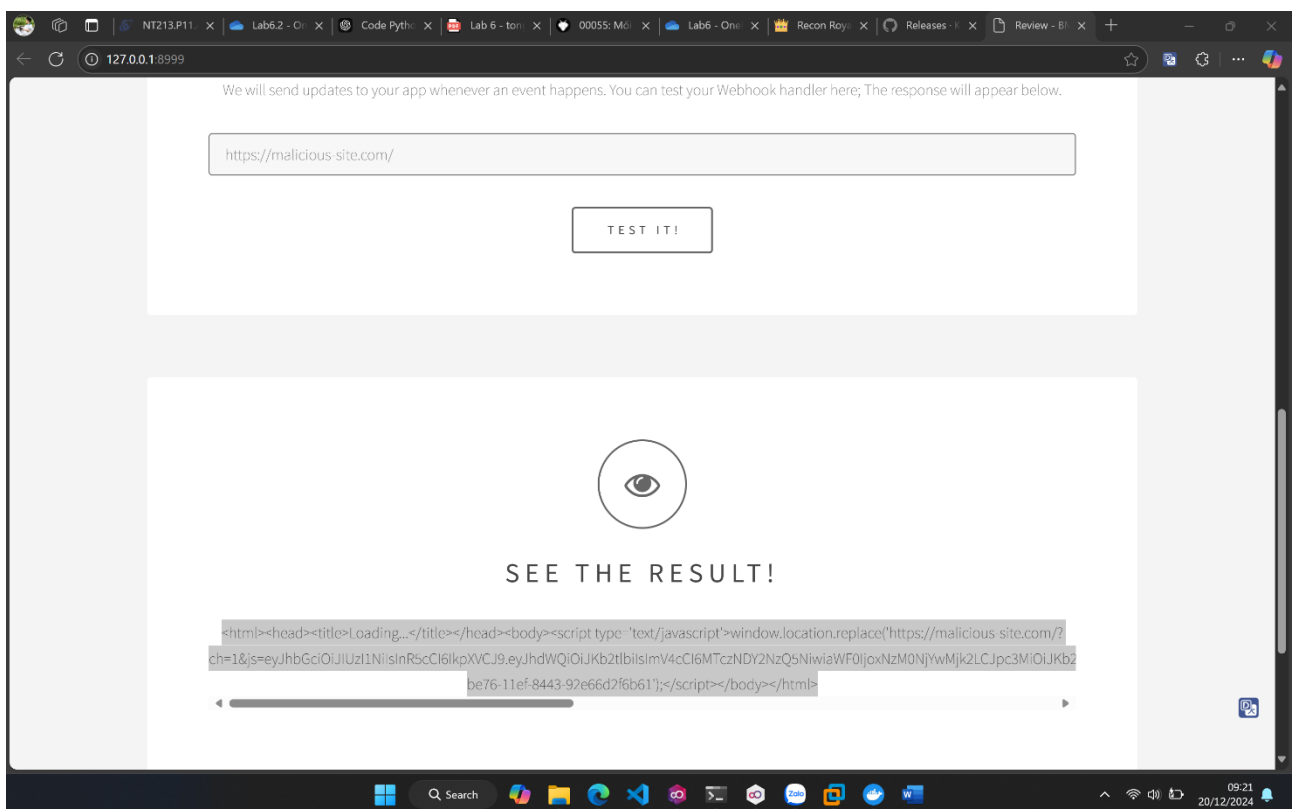
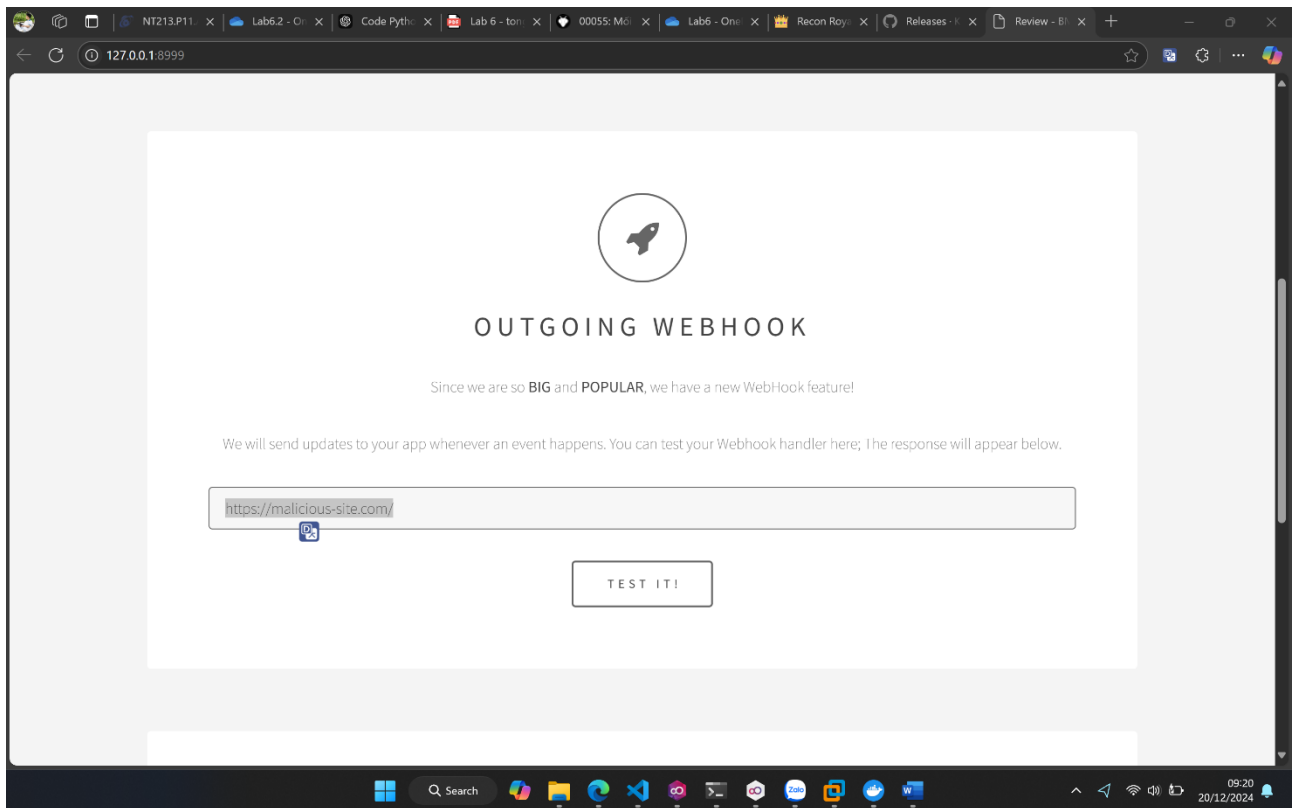
Tiêu đề: XSS – Cross-Site Scripting

- Mô tả lỗi hỏng:

- Tóm tắt: Giá trị input nhập vào không được kiểm tra, dẫn đến việc có thể chèn mã JavaScript độc hại và mã này được thực thi trên trình duyệt của người dùng khác.
- Các bước thực hiện:
 - Giá trị input nhập vào không được kiểm tra nếu ta nhập vào payload là một đường link URL độc hại như <http://malicious-site.com>.



- Thẻ `<input>` thiếu các trường để kiểm tra dữ liệu đầu vào => có thể dẫn đến lỗi hỏng XSS do không kiểm soát được dữ liệu.



- Mức độ ảnh hưởng lỗ hổng: Cao. Gây ảnh hưởng đến dữ liệu bảo mật của người dùng và uy tính của ứng dụng.
- Khuyến cáo khắc phục:

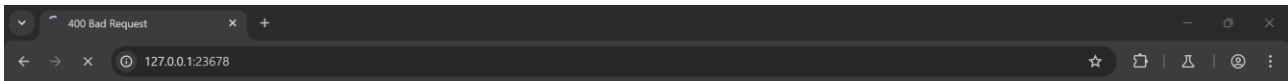
- Kiểm tra xác thực đầu vào: Chỉ chấp nhận với các URL hợp lệ trong danh sách whitelist và từ chối những URL chứa các ký tự đáng ngờ: `<script>`, các nhãn HTML không an toàn.
 - Định nghĩa CSP nghiêm ngặt để ngăn mã JavaScript chạy trực tiếp hoặc từ nguồn không tin cậy.
-

Yêu cầu 2: *Đề khai thác lỗ hổng Web*

– **Tiêu đề: Lỗ hổng *Broken Access Control*:**

- Mô tả lỗ hổng: Lỗ hổng liên quan đến quyền truy cập.
- Các bước thực hiện:

Truy cập web:



Bad Request

Forbidden: 'x' not allowed in Cache-Control header



- Ta check source code:

The screenshot shows a VS Code editor window with the following components:

- EXPLORER:** Displays the project structure for 'LAB2', including 'application' (with 'static/css' and 'main.css'), 'app.py', 'util.py', 'docker-compose.yml', 'Dockerfile', 'flag.txt', and 'requirements.txt'.
- OPEN EDITORS:** Lists the open files: 'util.py application', 'app.py application', 'docker-compose.yml', and 'LAB2'.
- EDITOR:** Shows the code for 'app.py' with the following content:

```
73 @app.route('/secret', methods=['GET', 'POST'])
74 @is_from_localhost
75 def dev_secret():
76     admin = "daffainfo"
77     css_url = url_for('static', filename='css/main.css')
78
79     if request.args.get('admin') is not None:
80         admin = request.args.get('admin')
81
82     if not admin:
83         abort(403)
84
85     template = '''<!DOCTYPE html>
86     <html lang="en">
87     <head>
88         <meta charset="UTF-8">
89         <meta name="viewport" content="width=device-width, initial-scale=1.0">
90         <title>Admin Notes Preview</title>
91         <link rel="stylesheet" href={}>
92     </head>
93     <body>
94         <h1>NOTES!! ONLY ADMIN CAN ACCESS THIS AREA!</h1>
95         <form action="" method="GET">
96             <label for="admin">Admin:</label>
97             <input type="text" id="admin" name="admin" required>
98             <br>
99             <input type="submit" value="Preview!">
100         </form>
101         <p>Admin: {}<span id="adminName"></span></p>
102     </body>
103     </html>'''.format(css_url, admin)
104     return render_template_string(template)
105
106 app.run(host='0.0.0.0', port=1337)
```
- TERMINAL:** Shows the output of the application running, displaying a GET request to / HTTP/1.1 with a 400 status code.
- STATUS BAR:** Indicates the current file is 'Ln 104, Col 44', using 'Spaces: 4', 'UTF-8' encoding, and 'LF' line endings. It also shows the Python version '3.12.5 64-bit' and the 'Go Live' extension.

Yêu cầu 3: *Đề tìm sub domains hợp lệ*

2. Tìm kiếm thông tin website trên internet.

Bài tập 3:(2đ) Tìm subdomain thuộc tên miền chính ở trang web sau: **arrow.com**

- Số lượng subdomain được accept cần vượt qua: 750 subdomain
- Dùng tool này để check số lượng domain: <https://recon-royale.com/validation.html>

Ta tìm được 599 subdomain:

```
@TanPMT →/workspaces/subbrute (master) $ python3 validation.py -l sub.txt -t arrow.com

=== Final Results ===
Total valid subdomains: 599
Total invalid subdomains: 2940
Total potential points on Recon Royale: -2341
```

Bằng cách ghép subdomain của từng nguồn khác nhau:

<https://subdomainfinder.c99.nl/scans/2024-12-19/arrow.com>

Result of arrow.com

<https://subdomainfinder.c99.nl/scans/2024-12-19/arrow.com>

Scan date	2024-12-19 23:48:31
Domain Country:	Worldwide (COM)
Subdomains found:	1480
Most used IP:	13.93.163.20 (38x)

Whois Check

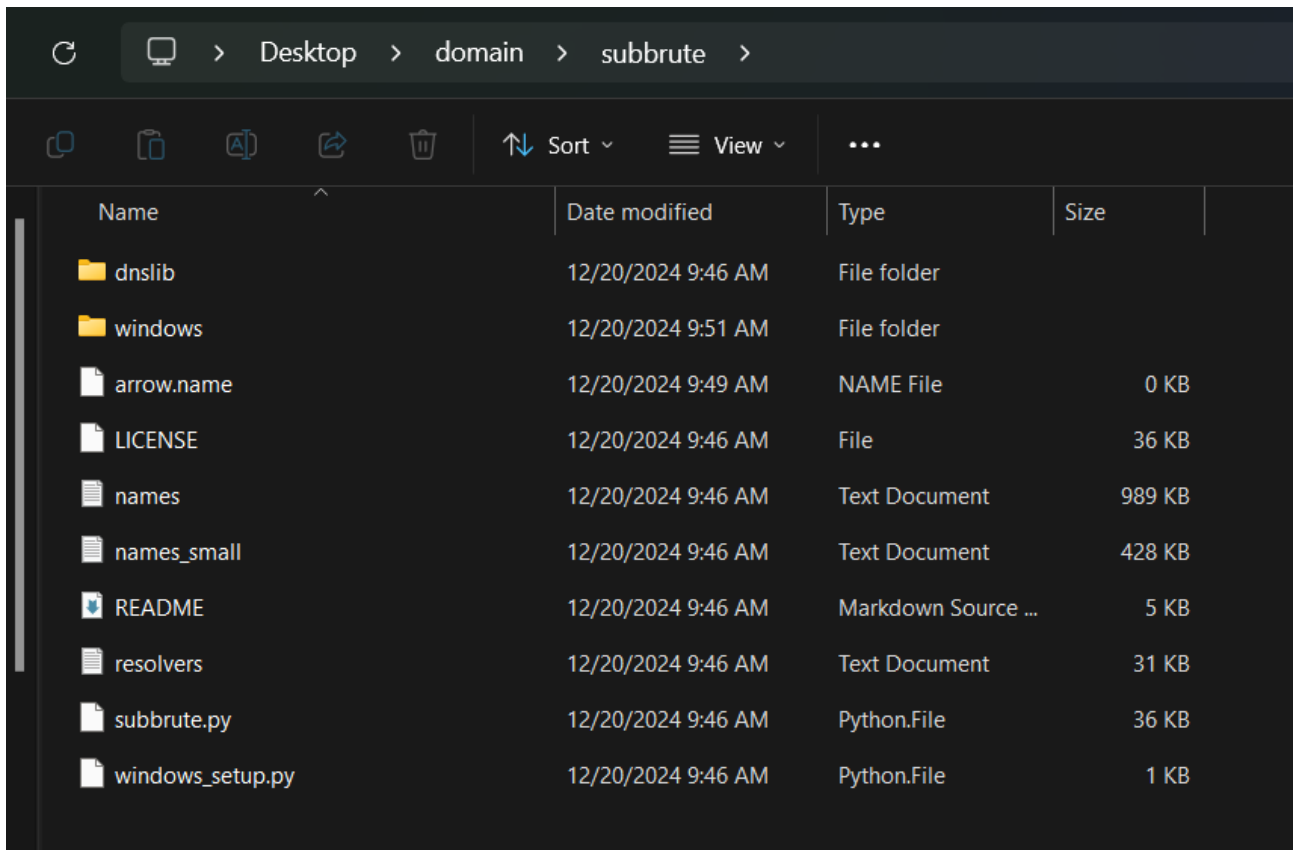
Check Status

Copy to clipboard

Download CSV

Download JSON

Dùng subbrute



The screenshot shows a file explorer window with the address bar displaying the path: Desktop > domain > subbrute. The window contains a table of files and folders.

Name	Date modified	Type	Size
dnslib	12/20/2024 9:46 AM	File folder	
windows	12/20/2024 9:51 AM	File folder	
arrow.name	12/20/2024 9:49 AM	NAME File	0 KB
LICENSE	12/20/2024 9:46 AM	File	36 KB
names	12/20/2024 9:46 AM	Text Document	989 KB
names_small	12/20/2024 9:46 AM	Text Document	428 KB
README	12/20/2024 9:46 AM	Markdown Source ...	5 KB
resolvers	12/20/2024 9:46 AM	Text Document	31 KB
subbrute.py	12/20/2024 9:46 AM	Python.File	36 KB
windows_setup.py	12/20/2024 9:46 AM	Python.File	1 KB

Yêu cầu 4: Đề# **Lỗi hỏng 1:**

- WebViewActivity được đánh dấu là “exported=true”, cho phép các ứng dụng bên ngoài có thể truy cập và mở bất kỳ URL nào thông qua intent.

```

AndroidManifest.xml
1. <?xml version="1.0" encoding="utf-8"?>
2. <manifest android:versionCode="1" android:versionName="1.0" android:compileSdkVersion="33" android:compileSdkVersionCodename="13" package="com.topip.netsight" platformBuildVersionCode="33" platformBuildVersionName="13">
3.     <uses-permission android:name="android.permission.INTERNET">
4.         <!-- Internet permission -->
5.     </uses-permission>
6.     <permission android:name="com.topip.netsight.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION" android:protectionLevel="signature" />
7.     <uses-permission android:name="com.topip.netsight.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION" />
8.     <application android:theme="@style/Theme.Netsight" android:label="@string/app_name" android:icon="@mipmap/ic_launcher" android:debuggable="true" android:allowBackup="true" android:supportRtl="true"
9.         <activity android:name="com.topip.netsight.MainActivity" android:exported="true" />
10.        <activity android:name="com.topip.netsight.WebviewActivity" android:exported="true" />
11.        <provider android:name="com.topip.netsight.MyContentProvider" android:exported="false" android:authorities="com.topip.netsight.FileProvider" android:grantUriPermissions="true">
12.            <data android:name="android.support.FILE_PROVIDER_PATHS" android:resource="@xml/provider_paths" />
13.        </provider>

```

- Bên trong WebViewActivity, WebView sử dụng JavaScript Interfaces như:
 - + showToast: Cho phép hiển thị thông báo từ chuỗi đầu vào.
 - + accessDeeplink: Cho phép xử lý và mở các intent được chỉ định bởi URL cung cấp

```

/* loaded from: classes3.dex */
public class WebviewActivity extends AppCompatActivity {
    WebView myWebView;
    String url;

    /* loaded from: classes3.dex */
    public class WebAppInterface {
        Context mContext;

        WebAppInterface(Context c) {
            this.mContext = c;
        }

        @JavascriptInterface
        public void showToast(String toast) {
            Toast.makeText(this.mContext, toast, 0).show();
        }

        @JavascriptInterface
        public void accessDeeplink(String url) {
            Uri uri = Uri.parse(url);
            Intent intent = new Intent();
            try {
                intent = Intent.parseUri(uri.toString(), 1);
            } catch (URISyntaxException e) {
                e.printStackTrace();
            }
        }
    }
}

```

- Điều này dẫn đến khả năng thực thi mã JavaScript độc hại, bao gồm cả khởi chạy các intent không an toàn.

- Code:

```
Intent intent = new Intent();

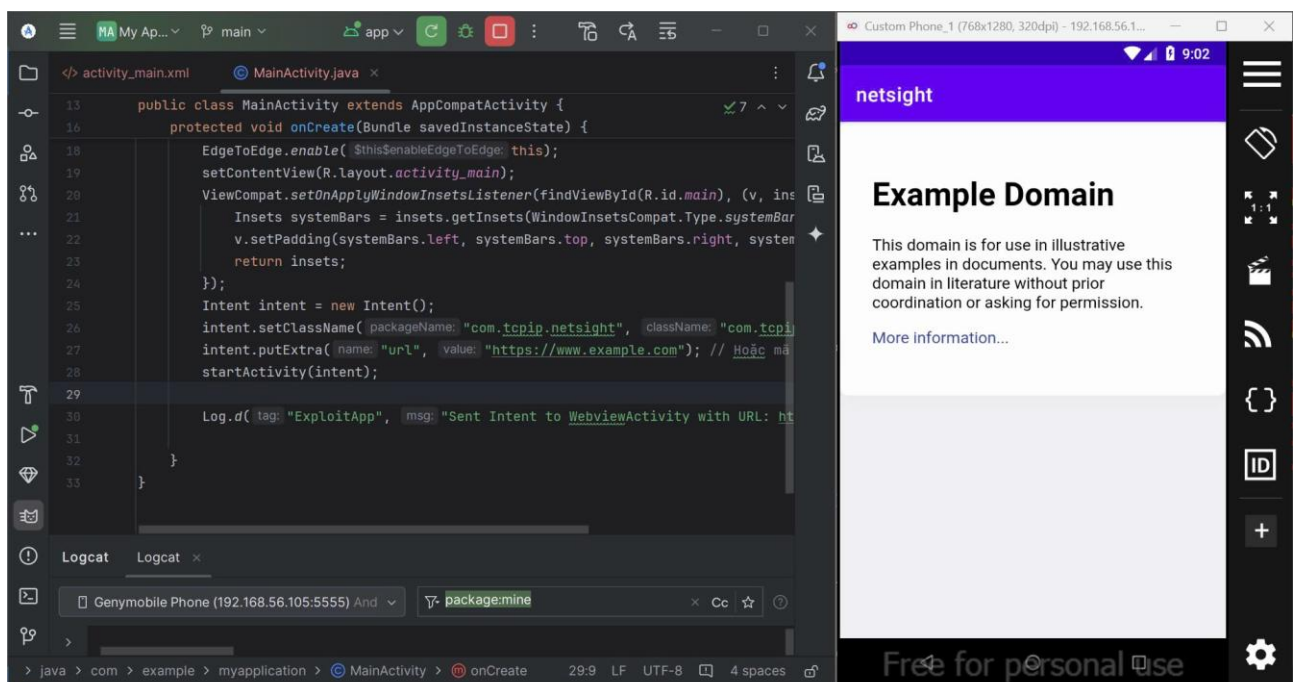
intent.setClassName("com.tcpip.netsight",
"com.tcpip.netsight.WebviewActivity");

intent.putExtra("url", "https://www.example.com"); // Hoặc mã JavaScript độc hại

startActivity(intent);

Log.d("ExploitApp", "Sent Intent to WebviewActivity with URL: https://www.example.com");
```

- Kết quả thực hiện:



Lỗi hỏng 2:

- PickerActivity nhận dữ liệu từ intent và chuyển tiếp nó mà không kiểm tra.
- Cờ FLAG_GRANT_READ_URI_PERMISSION được bật thông qua việc sử dụng getIntent().getData(), cho phép ứng dụng khác truy cập các tài nguyên nội bộ của ứng dụng (internal_files), do cấu hình sai trong provider_paths.xml.
- PickerActivity nhận dữ liệu từ intent và chuyển tiếp nó mà không kiểm tra.

```
package com.tcpip.netsight;

import android.content.Intent;
import android.os.Bundle;
import androidx.appcompat.app.AppCompatActivity;

/* loaded from: classes3.dex */
public class PickerActivity extends AppCompatActivity {
    /* JADX INFO: Access modifiers changed from: protected */
    @Override // androidx.fragment.app.FragmentActivity, androidx.activity.ComponentActivity, androidx.core.app.ComponentActivity, android.app.Activity
    public void onCreate(Bundle savedInstanceState) {
        super.onCreate(savedInstanceState);
        setContentView(R.layout.activity_picker);
        Intent intent = new Intent("android.intent.action.PICK");
        intent.setData(getIntent().getData());
        intent.setFlags(1);
        startActivityForResult(intent, requestCode:0);
    }
}
```

- Cờ FLAG_GRANT_READ_URI_PERMISSION được bật thông qua việc sử dụng getIntent().getData(), cho phép ứng dụng khác truy cập các tài nguyên nội bộ của ứng dụng (internal_files), do cấu hình sai trong provider_paths.xml.
- Mức Độ Nghiêm Trọng: rất nghiêm trọng
- Khai thác lỗ hổng này có thể dẫn đến:
 - + Mở các intent không an toàn, bao gồm khởi chạy các thành phần không được xuất bản.
 - + Rò rỉ dữ liệu nhạy cảm từ tệp nội bộ.
 - + Thực thi mã JavaScript độc hại, điều khiển hành vi của ứng dụng.
 - + Tạo điều kiện cho các cuộc tấn công leo thang đặc quyền hoặc rủi ro bảo mật khác.
- Cách Khắc Phục
 - + Đặt android:exported="false" cho WebViewActivity nếu không cần ứng dụng bên ngoài truy cập.
 - + Trước khi tải URL vào WebView, xác thực rằng URL là từ nguồn đáng tin cậy.
 - + Cấu hình lại provider_paths.xml để loại bỏ quyền truy cập toàn bộ nội dung nội bộ.
 - + Thêm kiểm tra dữ liệu nhận được từ intent trước khi sử dụng.
 - + Loại bỏ các interfaces không cần thiết khỏi WebView.

Yêu cầu 5: Báo cáo lỗ hổng trong app *video_player.apk*# **Tiêu đề:** *Mối nguy hiểm khi ứng dụng cho phép truy cập bộ nhớ ngoài theo cách cũ*

- Mô tả lỗ hổng:

- Tóm tắt: Trước đây, trên các phiên bản Android cũ (trước Android 10), các ứng dụng có thể dễ dàng truy cập bộ nhớ ngoài (external storage) bằng cách yêu cầu quyền (READ_EXTERNAL_STORAGE và WRITE_EXTERNAL_STORAGE). Điều này có thể dẫn đến các lỗ hổng như: Path Traversal. Nếu ứng dụng không kiểm tra đúng cách đường dẫn tập tin do người dùng cung cấp, kẻ tấn công có thể sửa đổi đường dẫn (path) để truy cập các tệp không mong muốn.
- Các bước thực hiện:
 - Truy cập AndroidManifest ta thấy được quyền truy cập bộ nhớ đều được cho phép

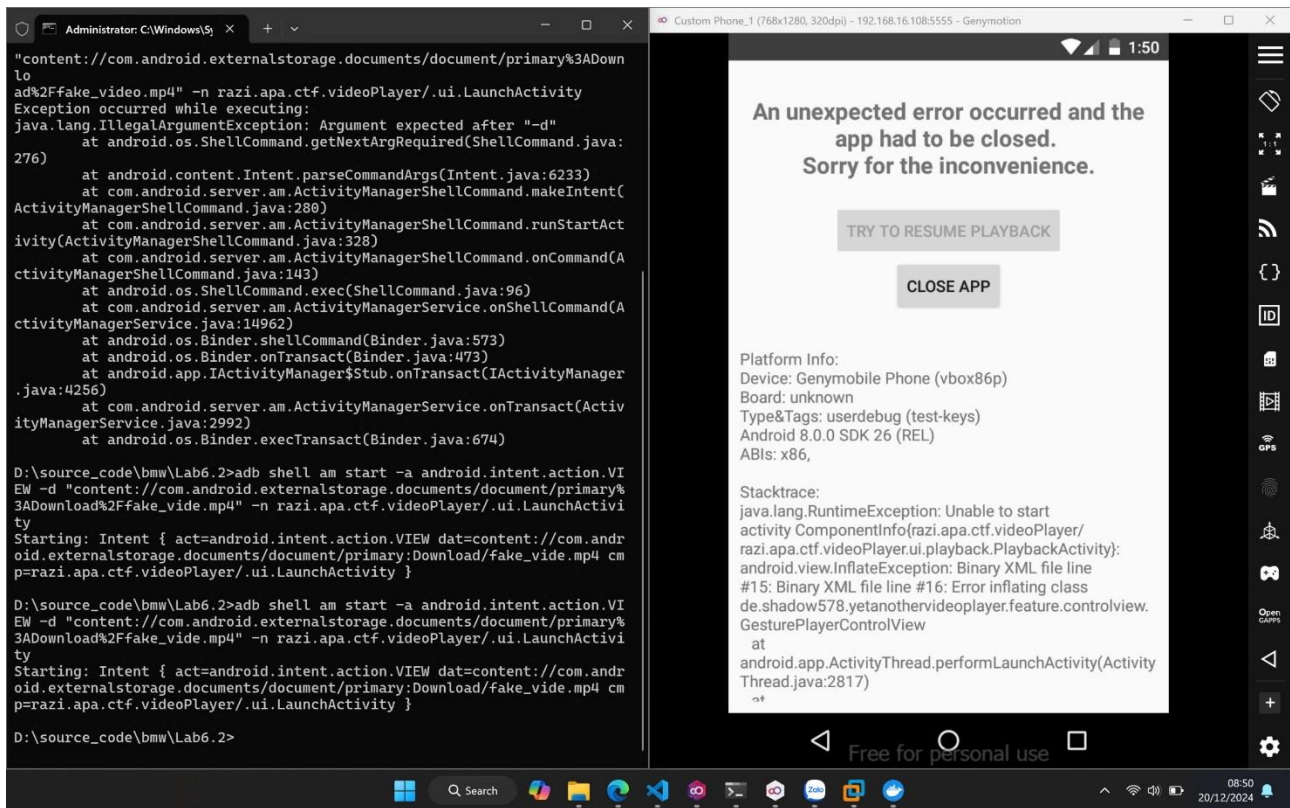
AndroidManifest.xml

```

1. <?xml version="1.0" encoding="utf-8"?>
2. <manifest android:versionCode="1" android:versionName="1.0" android:compileSdkVersion="29" android:compileSdkVersionCodename="10" package="razi.apa.ctf.videoPlayer" platformBuildVersionCode="29" platfo
3. xmlns:android="http://schemas.android.com/apk/res/android">
4. <uses-sdk android:minSdkVersion="23" android:targetSdkVersion="29" />
5. <uses-permission android:name="android.permission.MODIFY_AUDIO_SETTINGS" />
6. <uses-permission android:name="android.permission.INTERNET" />
7. <uses-permission android:name="android.permission.READ_EXTERNAL_STORAGE" />
8. <uses-permission android:name="android.permission.WRITE_EXTERNAL_STORAGE" />
9. <uses-permission android:name="android.permission.REQUEST_INSTALL_PACKAGES" />
10. <uses-permission android:name="android.permission.ACCESS_NETWORK_STATE" />
11. <application android:theme="@style/AppTheme.Light" android:label="@string/app_name" android:icon="@mipmap/ic_launcher" android:name="razi.apa.ctf.videoPlayer.YAVApp" android:allowBackup="true" and
12. <provider android:name="androidx.core.content.FileProvider" android:exported="false" android:authorities="razi.apa.ctf.videoPlayer.provider" android:grantUriPermissions="true">
13. <meta-data android:name="android.support.FILE_PROVIDER_PATHS" android:resource="@xml/provider_paths" />
14. </provider>
15. <activity android:label="@string/app_name" android:name="razi.apa.ctf.videoPlayer.ui.mediaPicker.MediaPickerActivity" />
16. <activity android:label="@string/settings_root_title" android:name="razi.apa.ctf.videoPlayer.ui.AppSettingsActivity" />
17. <activity android:label="razi.apa.ctf.videoPlayer.ui.PlayerDebugActivity" android:exported="true" />
18. <activity android:label="@string/app_name" android:name="razi.apa.ctf.videoPlayer.ui.CrashScreenActivity" />
19. <activity android:label="@string/app_name" android:name="razi.apa.ctf.videoPlayer.ui.playback.PlaybackActivity" android:configChanges="keyboard|keyboardHidden|orientation|screenLayout|screenSize
20. <activity android:name="razi.apa.ctf.videoPlayer.feature.gl.playCheck">
21. <intent-filter>
22. <action android:name="android.intent.action.MAIN" />

```

- Ta tạo một file fake_video.mp4 và chèn vào sdcard/Download/.
- Dùng lệnh để thực thi: Ta dùng script để đưa fake_video.mp4 vào app.
- Khi đó, ứng dụng sẽ không còn thực thi video ban đầu nữa mà chuyển sang thực thi một file khác.



- Mức độ ảnh hưởng: Gây ra ảnh hưởng nghiêm trọng đối với dữ liệu cá nhân của người dùng và dữ liệu của app.
- Khuyến cáo khắc phục:
 - o Xóa quyền truy cập bộ nhớ ngoài nếu không cần thiết.
 - o Kiểm tra xác thực dữ liệu đầu vào. Không để người dùng chèn dữ liệu không rõ nguồn gốc vào.
 - o Mã hóa dữ liệu.

----- HẾT -----